

Sasser Malware Research Report

Intern ID: 2172

Name: Lochana Arvind Patil

Topic: Sasser

Platform: RedKross Unified Threat Intelligence Platform

Introduction –

The [Sasser Worm](#) is a self-replicating computer worm discovered in 2004 that targeted vulnerable versions of Microsoft Windows XP and Windows 2000. It exploited a critical buffer overflow vulnerability in the LSASS to spread automatically across networks without requiring any user interaction.

Unlike many earlier malware threats that relied on email attachments or user actions, Sasser propagated by scanning random IP addresses for systems with port 445 open. Once a vulnerable machine was found, the worm would exploit the flaw to gain access and then transfer itself to the target system using a built-in FTP server. This made its spread extremely fast and difficult to contain.

One of the most noticeable symptoms of infection was system instability. Infected computers frequently crashed or displayed a system shutdown countdown due to failure in the LSASS process, forcing automatic restarts. This behavior caused widespread disruption, especially in environments where continuous system uptime was critical.

The worm quickly escalated into a global outbreak, affecting millions of computers and severely impacting major organizations, including airlines, financial institutions, hospitals, and government agencies. In some cases, operations were

temporarily halted, highlighting the vulnerability of critical infrastructure to cyber threats.

Several variants of Sasser (such as Sasser.A through Sasser.D) were later identified, each introducing minor modifications to improve propagation or evade detection. Despite these variations, all versions relied on the same fundamental LSASS vulnerability.

Importantly, a security patch had already been released by Microsoft before the outbreak occurred. However, many systems remained unpatched, allowing the worm to spread rapidly. This incident underscored the importance of timely software updates and led to increased emphasis on automated patch management and improved firewall protections in later operating systems.

The creator of the worm, Sven Jaschan, was eventually identified and arrested. His involvement brought attention to the growing threat posed by individual hackers capable of causing large-scale global disruption.

Overall, the Sasser worm marked a turning point in cybersecurity awareness, demonstrating how quickly network-based worms could spread and the critical need for proactive security measures in an increasingly connected digital world.

Executive Summary -

The Sasser worm was a highly disruptive self-propagating malware outbreak that spread by exploiting a buffer overflow vulnerability identified in Microsoft Security Bulletin MS04-011 (CVE-2003-0533). This vulnerability affected the LSASS in Windows operating systems, allowing the worm to execute code remotely and spread automatically without requiring any user interaction.

Although a security patch had already been released by Microsoft prior to the outbreak, a large number of systems remained unpatched. This delay in applying critical updates enabled the worm to propagate rapidly across global networks, infecting millions of machines within a short period.

The worm caused significant system-level and network-level disruptions, including:

- Continuous system crashes
- Automatic reboot cycles
- Heavy network congestion due to aggressive scanning
- Enterprise-wide service failures

The impact extended to major sectors worldwide, affecting critical operations in:

- Airlines
- Hospitals
- Banking systems
- Government infrastructure

Overall, the Sasser outbreak demonstrated the severe consequences of unpatched vulnerabilities and highlighted the importance of timely security updates, robust network defenses, and proactive cybersecurity practices in preventing large-scale cyber incidents.

Scope of the Platform -

This report focuses on a detailed analysis of the Sasser worm using a structured cyber threat intelligence framework. The objective is to provide both technical and analytical insights into the worm's behavior, impact, and mitigation strategies within real-world computing environments.

The scope of this report includes:

- **Malware lifecycle analysis and historical activity tracking**
Examination of the origin, development, variants, and timeline of the Sasser worm outbreak

- **Identification and correlation of Indicators of Compromise (IOCs)**
Analysis of key indicators such as IP addresses, exploited ports (e.g., port 445), and file signatures used to detect infections
- **Behavioral analysis of the worm**
Study of propagation techniques, including exploitation of the LSASS vulnerability, and its impact on system performance and stability
- **Technical study of exploited vulnerabilities**
In-depth understanding of the LSASS buffer overflow vulnerability and how it enabled remote code execution
- **Campaign-level activity and global impact assessment**
Evaluation of the scale of the attack, affected industries, and the broader implications on global cybersecurity practices
- **Detection mechanisms and prevention strategies**
Review of antivirus detection methods, intrusion detection systems, patch management, and best practices recommended by Microsoft and cybersecurity experts
- **Structured documentation of malware family characteristics**
Classification of Sasser within worm-based malware, including its variants, signatures, and distinguishing technical features

Core Intelligence Modules -

Module	Purpose	Key Output
Malware Analysis	In-depth study of Sasser's behavior and propagation mechanisms	Infection chain, payload execution, system impact
IOC Analysis	Identification and correlation of Indicators of Compromise (IOCs)	Malicious ports (e.g., 445), IP patterns, signatures
Threat Activity	Tracking and analysis of outbreak timeline and spread patterns	Chronological timeline, rate of global propagation
Detection Module	Evaluation of detection and prevention mechanisms	Patch deployment, firewall rules, mitigation strategies

APT Intelligence Data Model -

- ★ APT Name and Aliases:

- **Primary Name:** Sasser

- **Aliases:**

- W32/Sasser
- Worm.Sasser
- Sasser.A
- Sasser.B

★ Life-time / Active Period:

- **First Observed:** April 2004
- **Major Outbreak Period:** May 2004
- **Active Variants:** 2004–2005
- **Current Status:** Historically inactive but remains a major case study in malware analysis.

★ Threat Actor Type and Motivation:

- **Threat Actor Type:** Independent malware author / worm developer
- **Motivation:**
 - Experimentation
 - Disruption
 - Technical challenge rather than financial gain

The worm was not designed for ransomware or data theft but focused primarily on rapid self-propagation and disruption of vulnerable systems.

★ Known People / Operators / Public References:

- **Known Author:** Sven Jaschan
- **Nationality:** German
- **Age at Arrest:** 18 years old
- Arrested in May 2004 after Microsoft announced a reward for information about the creator of the worm.

★ TTPs Mapped to MITRE ATT&CK:

Technique	MITRE ID	Description
-----------	----------	-------------

Exploit Public-Facing Application	T1190	Exploits LSASS vulnerability
Remote Services	T1021	Uses network services for propagation
Command and Scripting Interpreter	T1059	Executes malicious code remotely
Network Service Scanning	T1046	Scans IP ranges for vulnerable systems
Automated Collection / Propagation	T1210	Self-spreading worm behavior

★ IOC List (Indicators of Compromise)

- IPs / Network Activity
 - Random IP scanning behavior
 - Excessive traffic on TCP Port 445
- Ports Used
 - TCP 445 → Vulnerability scanning
 - TCP 9996 → Remote shell
 - TCP 5554 → FTP transfer

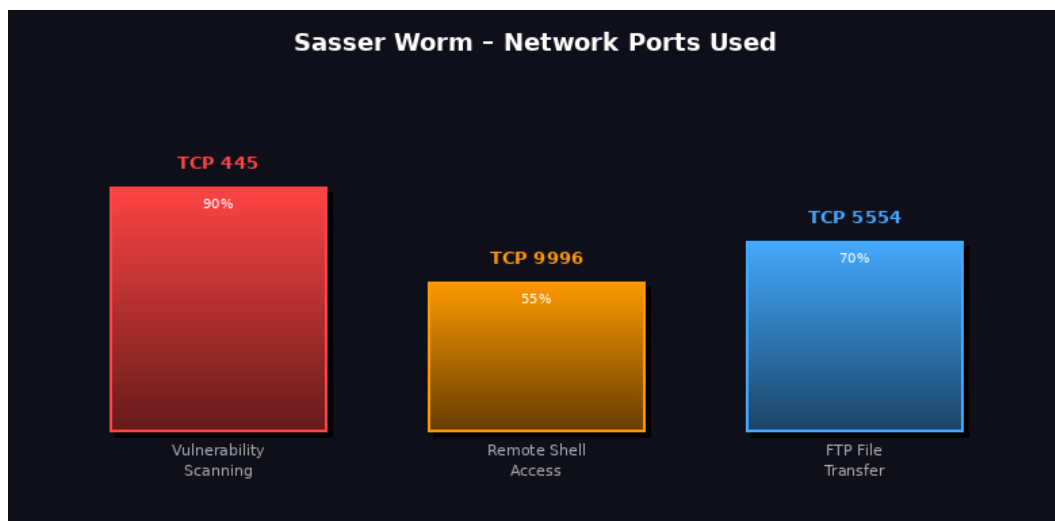


Figure: Sasser Network Port Activity

- Known File Names:
 - avserve.exe
 - avserve2.exe
 - skynetave.exe
- File Extensions: .exe

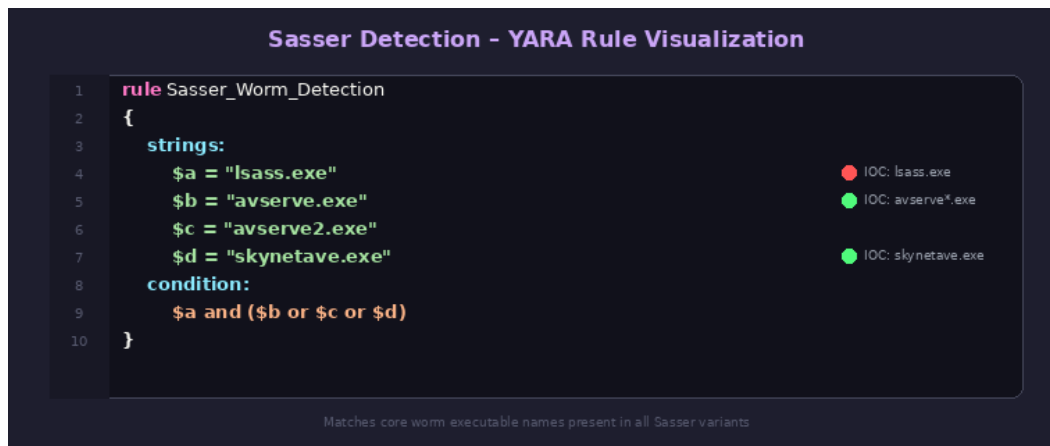


Figure: Sasser YARA Detection Rule

- URLs / Domains:
 - No major centralized command-and-control domain structure observed.
- Mutexes:
 - Variant-specific mutex behavior reported in malware analyses.

★ Campaign List with First-Seen and Last-Seen Dates:

Campaign ID	First Seen	Last Seen	Description
CAMP-001	April 2004	May 2004	Initial global outbreak
CAMP-002	May 2004	Late 2004	Variant propagation campaigns

★ Victim Countries and Target Industries:

- Victim Countries
 - United States
 - Germany
 - United Kingdom
 - Australia
 - Multiple European nations
- Target Industries
 - Airlines
 - Healthcare

- Banking
- Government agencies
- Telecommunications

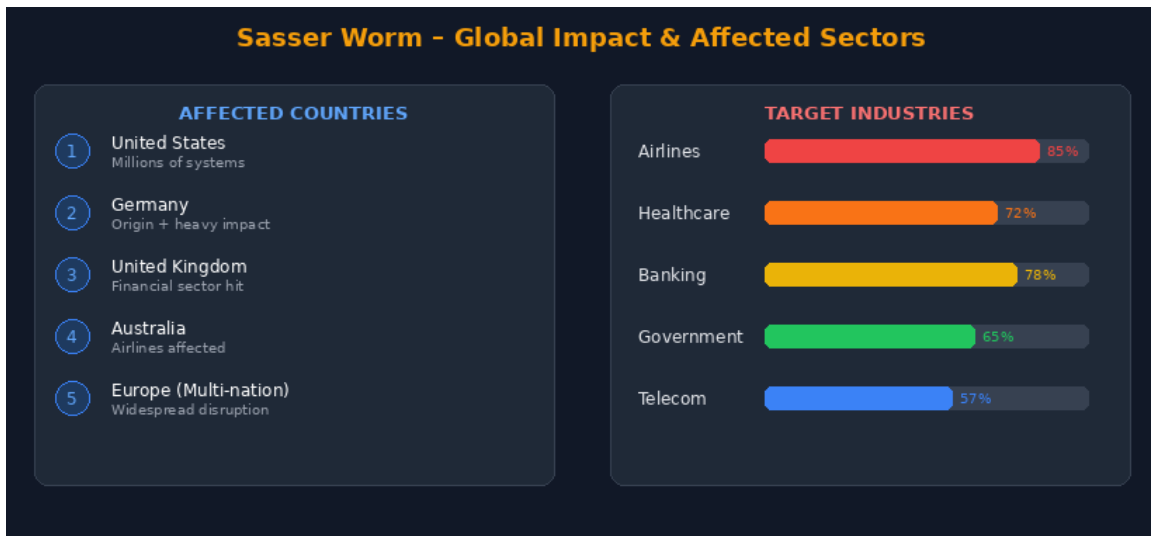


Figure: Sasser Global Impact by Country and Sector

★ Observed Malware Families and Tools:

- Sasser Worm variants
- LSASS exploit-based propagation tools
- FTP transfer utilities used during infection process

★ Infrastructure Notes:

- No sophisticated command-and-control infrastructure
- Relied on direct network propagation
- Aggressive IP scanning behavior
- Exploited weak patch management in enterprise systems
- Minimal cleanup or stealth functionality

★ New Activity Timeline and Behavioral Changes:

Time Period	Activity
-------------	----------

April 2004	Initial worm development
May 2004	Massive worldwide outbreak
Mid 2004	Release of multiple variants
Late 2004	Patch adoption reduced infections

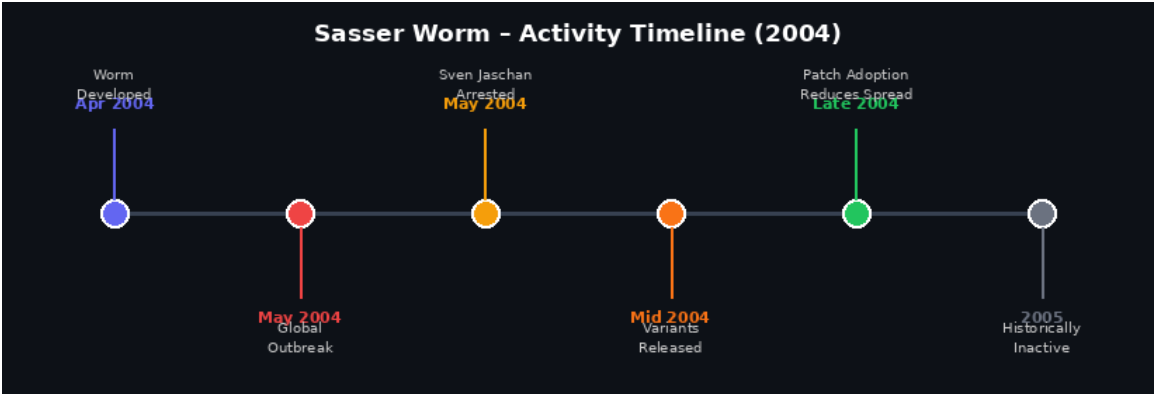


Figure: Sasser Worm Activity Timeline 2004

★ Links to Related APT Groups and Overlaps:

Although Sasser itself was not directly linked to a formal APT group, its propagation techniques influenced later worm-based attacks and demonstrated methods later observed in advanced cyber campaigns involving automated exploitation and rapid network propagation.

Campaign Tracking Fields – Sasser Worm -

Table 1: Basic Campaign Information

Campaign ID	Threat Actor	Activity Period (UTC)	Victim Country	Target Industry
CAMP-001	Sven Jaschan	April 2004 – May 2004	USA, Germany, UK, Australia	Airlines, Healthcare, Banking, Government

CAMP-002	Same Actor (Variants)	May 2004 – Late 2004	Europe, North America	Telecom, Enterprises
CAMP-003	Independent Spread (Residual infections)	2004 (Post-outbreak)	Global	Mixed sectors

Table 2: Technical Campaign Details

Campaign ID	TTPs	IOC	Summary	Notes
CAMP-001	T1190, T1046, T1210	Port 445 scanning, avserve.exe	Initial global outbreak exploiting LSASS vulnerability	Rapid spread due to unpatched systems
CAMP-002	T1046, T1021	FTP (5554), Port 9996 activity	Variant-based propagation with modified behavior	Increased system crashes and network load
CAMP-003	T1210	Continuous scanning activity	Residual infections in unpatched machines	Decline after patch adoption

Malware Family Documentation -

★ Family Name and Aliases:

- **Family Name:** Sasser
- **Aliases:**
 - W32/Sasser
 - Worm.Sasser
 - Sasser.A, Sasser.B, Sasser.C

★ Discovery History and Timeline:

- **April 2004:** Sasser worm discovered
- **May 2004:** Massive global outbreak
- **Mid 2004:** Multiple variants released
- **Late 2004:** Spread reduced after patching
- Became one of the fastest-spreading worms of its time

★ Original Purpose and Evolution:

- Initially created for **experimental purposes** by the author
- Not designed for financial gain (unlike ransomware)
- Focused on **self-propagation and disruption**
- Later variants modified behavior slightly but kept same core exploit

★ Technical Characteristics and Behavior:

- Exploits **LSASS vulnerability (buffer overflow)**
- Does **not require user interaction**
- Automatically scans random IP addresses
- Causes:
 - System crashes
 - LSASS.exe failure
 - Forced reboot cycles
- Consumes high CPU and network resources

★ Known Hashes, Signatures, and YARA Rules:

- Multiple variant-specific hashes (not fixed due to mutation)
- Antivirus signatures available for detection
- Example YARA logic (basic concept):

```
rule Sasser_Worm_Detection
{
  strings:
    $a = "lsass.exe"
    $b = "avserve.exe"
  condition:
    $a and $b
}
```

★ Associated APT Groups and Campaigns:

- No formal APT group association
- Created by **Sven Jaschan**
- Related to:
 - CAMP-001 (Initial outbreak)
 - CAMP-002 (Variants)
 - CAMP-003 (Residual spread)

★ Typical TTPs and Infection Chain:

- **TTPs:**
 - T1190 – Exploit public-facing application
 - T1046 – Network scanning
 - T1210 – Exploitation of remote services

★ Infection Chain (Flow):

Scan IP Range
↓
Detect Port 445
↓
Exploit LSASS Vulnerability
↓
Open Shell (9996)
↓
Transfer via FTP (5554)

↓
Execute Worm
↓
Repeat Spread

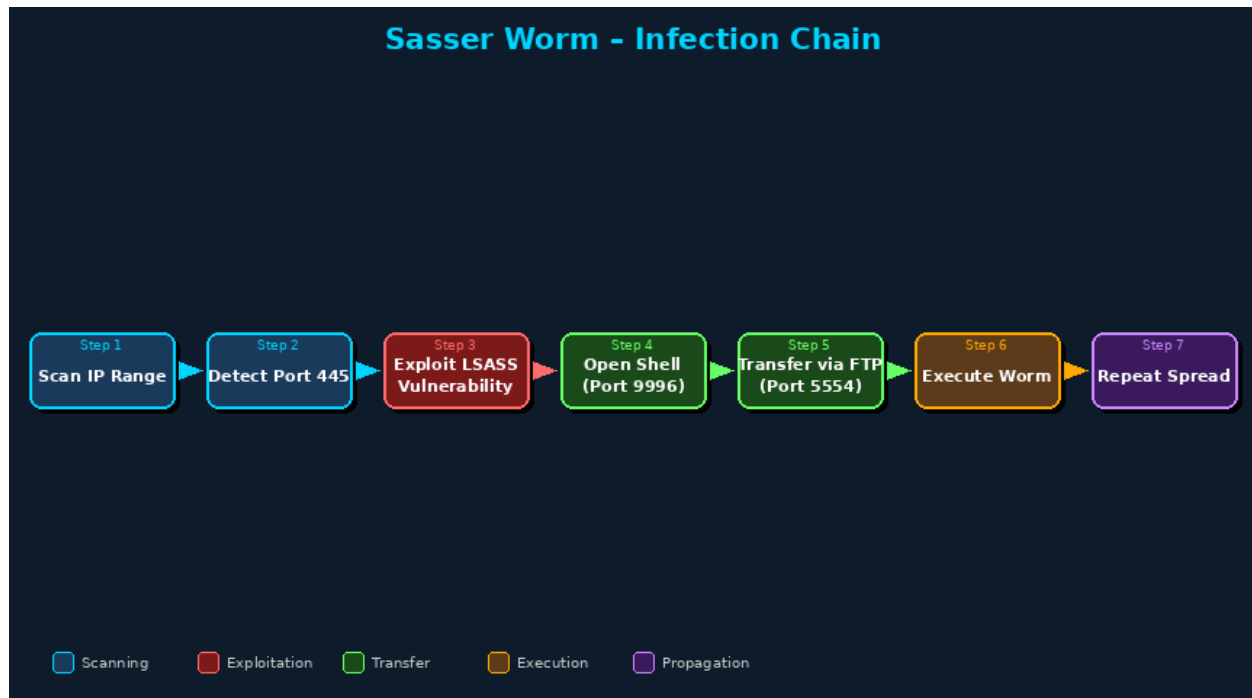


Figure: Sasser Infection Chain Flow

- ★ Network Indicators, Domains, and IPs:
 - No centralized command-and-control domains
 - Key indicators:
 - Port 445 scanning
 - Port 9996 shell access
 - Port 5554 FTP traffic
 - Random IP targeting pattern

- ★ Persistence, Privilege Escalation, and Exfiltration Behavior
 - **Persistence:** Runs automatically after infection
 - **Privilege Escalation:** Achieved via LSASS exploit
 - **Exfiltration:**

- No data theft behavior
- Focused only on spreading

- ★ Unique File System or Artifact Patterns
 - Creation of log files:
 - C:\win.log
 - C:\win2.log
 - Presence of worm executables in system directories
 - System instability and repeated crash artifacts

- ★ Links to Samples, Reports, and Family-Specific Pages:
 - Wikipedia reference (primary source) -
[https://en.wikipedia.org/wiki/Sasser_\(computer_worm\)](https://en.wikipedia.org/wiki/Sasser_(computer_worm))
 - Antivirus vendor reports (Symantec, Kaspersky)
 - Malware analysis repositories

Ransomware Family Pages -

The **Sasser Worm** is a network worm and does not belong to the ransomware category. It does not perform file encryption, extortion, or ransom demand activities.

However, for format consistency, a brief analysis is provided below:

- **Ransomware Name and Aliases:** Not applicable (Sasser is a worm)
- **First Observed Activity:** April 2004
- **Latest Observed Activity:** Late 2004
- **File Extension Behavior:** Not applicable (no encryption or file modification)
- **Encryption and Extortion Style:** Not applicable (no ransom demand)
- **Leak Portals / Onion Links:** None observed
- **Associated Threat Actor:** Sven Jaschan

- **Observed Behavior:** Network-based propagation, system crashes, and service disruption.
- **Infrastructure:** Uses ports 445, 9996, and 5554 for spreading.

Library Folder Review Workflow -

The library folder review workflow is a structured process used to analyze a collection of malware-related files as a single intelligence unit. In the context of the **Sasser Worm**, this workflow helps in systematically examining multiple samples, logs, and supporting files.

Workflow Steps:

Step 1: Assign Folder Details

- **Folder Name:** Sasser_Malware_Analysis
- **Owner:** Security Research Team
- **Review Date:** 21 May 2026

Step 2: Divide Files into Batches

- If the folder contains 100 files and 10 students are assigned:
- Each student analyzes **10 files**
- Ensures equal workload and organized review

Step 3: Extract File Information

- For each file, collect:
- File Name
- File Type (.exe, .log, .txt)
- Hash Value (if available)
- Date Created
- Source

- Relevance

Step 4: Tag Each File

- Each file is categorized as:
- **Important** → Core malware files
- **Suspicious** → Unknown or risky
- **Duplicate** → Repeated files
- **Reference-only** → Notes or documentation

Step 5: Write Short Notes

File Name	Description	Notes / Significance
avserve.exe	Primary executable of the Sasser worm	Responsible for propagation, exploitation, and payload execution
win.log	Log file created during infection process	Stores activity records, may help in forensic analysis
sample.txt	Reference or placeholder file (non-malicious)	Not directly related to worm execution; used for documentation or testing

Step 6: Summarize Findings

- Multiple Sasser variants observed
- Common behavior: LSASS exploitation
- Frequent use of ports 445 and 5554
- Presence of duplicate samples

Step 7: Flag Issues

- Missing files (if expected samples not found)
- Corrupted files
- Duplicate entries

Step 8: Final Folder Report (Evidence Table)

File Name	Type	Tag	Notes
avserve.exe	.exe	Important	Core worm file
avserve2.exe	.exe	Important	Variant sample
win.log	.log	Reference	Infection log
sample.txt	.txt	Reference	Documentation

Final Deliverables -

The following deliverables are produced as part of the comprehensive analysis of the Sasser worm. These outputs collectively provide technical, analytical, and intelligence-driven insights into the malware's behavior, impact, and detection:

★ APT Profile Pages:

- Detailed profile of the Sasser worm, including aliases, variants, lifecycle stages, and behavioral characteristics.
- Attribution insights related to Sven Jaschan.
- Contextual understanding of the threat actor and motivations.

★ Campaign Timeline Dashboard:

- Visual and structured timeline of the Sasser outbreak (April–May 2004).
- Identification of multiple campaign phases and variant evolution.
- Analysis of propagation speed and global spread patterns.

★ IOC Knowledge Base:

- Comprehensive repository of Indicators of Compromise (IOCs), including:
 - Network ports (445, 9996, 5554)
 - Malicious file names (e.g., `avserve.exe`)
 - Network scanning and propagation patterns
- Enables efficient detection and incident response.

★ **Malware Family Pages:**

- Complete documentation of the Sasser malware family.
- Technical breakdown of infection chain, payload execution, and system impact.
- Comparative analysis of different Sasser variants.

★ **Ransomware Classification Analysis:**

- Analytical assessment confirming that Sasser is **not ransomware**.
- Clear distinction based on absence of encryption mechanisms and extortion behavior.
- Helps avoid misclassification in threat intelligence systems.

★ **YARA and Detection Library:**

- Development of basic YARA rules for identifying Sasser infections.
- Detection patterns based on exploitation of the LSASS vulnerability.
- Supports automated threat detection and monitoring systems.

★ **Research Notes and Evidence Tables:**

- Detailed file-level observations and behavioral notes.
- Documentation of malware samples, logs, and analysis findings.
- Evidence-based tables supporting conclusions drawn in the report.

★ **Library-Folder Analysis Reports:**

- Structured workflow documentation for analyzing multiple malware files.
- Consolidated evidence tables summarizing file attributes, classification, and relevance.
- Ensures consistency, traceability, and reproducibility of analysis.